

PRODUCT REQUIREMENTS DOCUMENT

AI-Augmented Security Posture Intelligence Platform

v1.1 · Draft · May 21, 2026

Owners: Sathish & Karthik

1. Document Control

Field	Value
Document Title	Product Requirements Document — Security Posture Intelligence Platform
Version	1.1
Status	Draft — for engineering kickoff (revised with competitive analysis vs DefectDojo)
Date	May 21, 2026
Owners	Sathish (Backend / Security / AI), Karthik (Frontend / Deploy)
Stakeholders	Engineering team, first design-partner customer, prospective Pro-tier buyers
Changes in v1.1	Added §12 Competitive Landscape; added 6 differentiator features (FR-SCN-12, FR-SCN-13, FR-AI-08, FR-AI-10, FR-OUT-04, FR-UI-08); deferred FR-AI-03, FR-OUT-06, scan delta UI to v1.1
Related Docs	12-Week Daily Build Plan v1.0 (Next.js stack), SECURITY.md, SCHEMA.md

2. Executive Summary

Mid-market security teams (10–500 engineers) drown in raw scanner output. Nuclei, Trivy, Gitleaks, Prowler, and Snyk each emit hundreds of CVEs per scan with little prioritization context. Severity (CVSS) alone is widely understood to overstate risk — most CRITICAL CVEs are never exploited, and some MEDIUM CVEs are actively weaponized.

This platform unifies vulnerability (Nuclei), container/SCA (Trivy), and secret (Gitleaks) scanning into a single multi-tenant SaaS, then enriches every finding with three independent risk signals — NVD CVSS, CISA KEV (known-exploited), and FIRST EPSS (exploitation probability) — and an Anthropic Claude-generated plain-English explanation and remediation plan. A composite priority score multiplies these signals against per-asset criticality weights set by the customer.

Beyond enrichment, six features distinguish us structurally from the closest competitor (DefectDojo, an ingest/aggregation platform): we run scanners on PR diffs as a GitHub App (FR-SCN-12); validate exploitability of critical findings with active probes (FR-SCN-13); check source-call reachability for SCA findings against actual code (FR-AI-08); ship a native Claude agent that answers 'what should I fix this sprint?' (FR-AI-10); open AI-generated fix PRs not just Jira tickets (FR-OUT-04); and provide a single-screen, projection-ready CISO view (FR-UI-08). These six are not 'features DefectDojo lacks' — they are features they cannot ship without becoming a different product, because they do not run scans or hold source code at scan time.

Pricing tiers (Free / Starter \$29 mo / Pro \$199 mo / Enterprise contact) match cost structure of Anthropic API + Hetzner compute. See §12 Competitive Landscape for full positioning.

v1.0 ships in 12 weeks with one paying customer. Cloud scanning (Prowler), IaC (Checkov), and compliance report packs are deferred to v1.1+ to keep the timeline credible.

3. Problem Statement

3.1 The buyer pain

- A security engineer running Trivy on a single Docker image sees 40+ CVEs. CVSS 9.8 might be a transitive dep never reached at runtime; CVSS 6.5 might be the actively-exploited one. They have no fast way to know.
- Tools don't talk: Nuclei findings go nowhere, Trivy goes nowhere, Gitleaks goes nowhere. Each requires a manual triage step into Jira.
- Executives ask 'what's our top risk this week?' — the engineer has no defensible answer beyond a CVSS histogram.
- Compliance audits demand evidence; current state is screenshots in Confluence.

3.2 Why now

- EPSS data went mainstream in 2023; CISA KEV catalog is now the de facto 'fix-immediately' list. Both are public APIs.
- Claude (and peer LLMs) reached a level in 2024–2025 where structured CVE explanations are genuinely useful and cheap (sub-cent per finding).
- Mid-market still buys point tools; few unified-intelligence vendors below the enterprise (Wiz, Snyk Enterprise) price point.

3.3 Why not the existing solutions

- Wiz / Snyk Enterprise: \$50k+ ACV, sold to Fortune 1000. Out of reach for our SMB/mid-market buyer.
- DefectDojo (closest direct competitor): mature open-source + paid platform with 200+ tool integrations and recent AI features. Strong for customers who already operate a multi-scanner stack. Weaker for the no-existing-AppSec-team buyer because it ingests but does not run scans; weaker on shift-left (no PR-time scanning), reachability against source, and fix-PR generation. See §12 for detailed positioning.
- Nessus / Qualys: scanner-first, weak workflow story, dated UX, no AI/intel-driven prioritization.
- Aikido Security: closest in positioning (SaaS, AI, multi-scanner); active competitor; differentiate on AI quality and on FR-SCN-12 / FR-AI-08 / FR-OUT-04.

4. Goals and Non-Goals

4.1 Goals (v1.0)

- Ship a multi-tenant SaaS in 12 weeks with a paying first customer by end of Week 12.
- Deliver a clearly differentiated value prop: 3 free scanners + intel + AI = actionable risk, not noise.
- Keep AI cost-per-scan below 30% of Starter-tier revenue.
- Achieve zero cross-tenant data leaks in production.
- Lighthouse Performance ≥85 and Accessibility ≥90 on core flows.

4.2 Non-Goals (explicitly out of scope for v1.0)

- Becoming a cloud security posture management (CSPM) tool — that's Wiz's territory.

- Replacing engineering ticketing systems — we integrate with Jira, we don't host tickets.
- On-prem / air-gapped deployment — SaaS-only for v1.0.
- Real-time agent-based monitoring — we are scan-based; agents are a separate product.
- Bug bounty platform features — not our wedge.

5. Target Users & Personas

Primary buyer is the security engineer; primary economic buyer (signs the invoice) is the CISO/Director. DevOps Lead is the influencer who often triggers the trial.

Persona	Role / Context	Goals	Pain Today
Priya — Security Engineer	Mid-market SaaS, team of 3, owns app + cloud security	Find real risks fast; spend less time triaging noise	Drowning in tool dashboards; CVSS alone doesn't tell her what's exploitable
Daniel — DevOps Lead	200-engineer fintech; runs CI/CD; security adjacent	Catch issues before prod; integrate scans into pipeline	Tools fight CI runtime; PRs slowed by unclear findings
Maya — CISO / Director	Series B SaaS; reports to CEO/board	Defensible posture story; quarterly evidence; clear ROI	Spreadsheet reports; can't answer 'what's our top risk this week?'
Ravi — Compliance Manager	Pursuing SOC2 Type II	Audit-ready evidence of vulnerability management	Manual screenshots; weak vendor risk story

6. Key User Stories

6.1 First-scan flow (Priya, day 1)

As a security engineer, I want to sign up, add my company's main web app and main Docker image, run one scan, and see prioritized findings with AI-written remediation steps within 10 minutes of landing on the site — so I can decide in one session whether this tool is worth paying for.

6.2 Triage flow (Priya, day 5)

As a security engineer, I want to open today's scan, see the Top 10 findings ranked by priority_score (not just CVSS), click into any finding, read the plain-English explanation, and create a Jira ticket with one click — so I can clear my triage queue in 30 minutes instead of 3 hours.

6.3 Executive reporting (Maya, end of month)

As a CISO, I want to download a PDF executive summary of all scans this month with a 3–5 sentence narrative and top-10 risks — so I can present it to the board without engineering rewriting it for me.

6.4 CI/CD integration (Daniel, week 2 of trial)

As a DevOps lead, I want to fire scans from our CI pipeline via API and have failed builds when CRITICAL+KEV findings are introduced — so security never blocks deploys but never gets ignored either.

6.5 Compliance evidence (Ravi, audit prep)

As a compliance manager, I want a full audit log of who scanned what when, plus a CSV export of all findings and their status — so I can satisfy SOC2 CC7.1 (vulnerability management) without spreadsheet wrangling.

7. Functional Requirements

Priority key: P0 = must ship for v1.0; P1 = should ship for v1.0; v1.1/v1.2 = explicitly deferred.

7.1 Authentication & Multi-tenancy

ID	Requirement	Priority	Acceptance Criteria
FR-AUTH-01	Email + password sign-up with email verification (6-digit OTP)	P0	User submits signup form, receives OTP within 30s, can verify within 10 min
FR-AUTH-02	Sign-in via Auth.js v5 Credentials provider proxying to FastAPI /auth/token	P0	Returns JWT (8h default, 30d with 'remember me'); middleware enforces (app)/* protection
FR-AUTH-03	Role-based access control: admin / analyst / viewer	P0	Viewer cannot POST /scans; analyst cannot create users; enforced server-side
FR-AUTH-04	Strict multi-tenant isolation by org_id on every query	P0	Cross-tenant probe test: 0 leaks across 100 endpoint × org combinations
FR-AUTH-05	Password reset via emailed signed token (24h expiry)	P1	User completes reset flow; old sessions invalidated
FR-AUTH-06	SSO (SAML/OIDC)	v1.2	Deferred; Enterprise tier only

7.2 Asset Management

ID	Requirement	Priority	Acceptance Criteria
FR-AST-01	Add asset (manual): name, type (URL/image/repo), criticality weight (Low 0.5 / Med 1.0 / High 1.5 / Critical 2.0)	P0	Asset appears in /assets list; weight respected in priority calc
FR-AST-02	Auto-register asset on first scan if target not in assets table	P0	Scan against new target creates Asset row with default weight 1.0
FR-AST-03	Inline edit of asset weight from /assets table	P0	Change persists; findings on that asset re-ranked within 60s

ID	Requirement	Priority	Acceptance Criteria
FR-AST-04	Asset bulk import via CSV	v1.1	Deferred

7.3 Scanning Engine

ID	Requirement	Priority	Acceptance Criteria
FR-SCN-01	On-demand scan via UI: choose target + scan types (Vuln / SCA / Secrets)	P0	Scan created in <2s; status visible immediately
FR-SCN-02	Three integrated scanners: Nuclei (web vuln), Trivy (container/SCA), Gitleaks (repo secrets)	P0	Each scanner outputs Finding rows with org_id, asset_id, severity, raw output
FR-SCN-03	Parallel execution via Celery group + chord; one tool failure does not kill the scan	P0	Kill nuclei mid-scan; trivy + gitleaks complete; scan marked partial_success
FR-SCN-04	Live progress via SSE (EventSource) with TanStack Query fallback polling	P0	Progress bar updates within 10s of state change
FR-SCN-05	Rate limiting: 10 scans/hour per org (Free tier)	P0	11th scan returns 429 with upgrade link
FR-SCN-06	Input validation: reject 127.0.0.1, RFC1918, malformed URLs/repo URLs	P0	Scan with target=127.0.0.1 returns 400
FR-SCN-07	Scan timeout safety: 30 min hard limit; stuck scans marked failed	P0	Scan held >30 min is failed and visible to user
FR-SCN-12	★ DIFFERENTIATOR — PR-time scanning via GitHub App. On every PR: scope scanners to changed files; post inline file:line annotations + Checks API status + PR comment summary	P0	GitHub App installs; PR opened on test repo triggers scan; findings appear as inline annotations in 'Files changed' tab within 90s
FR-SCN-13	★ DIFFERENTIATOR — Exploit validation mode. For critical findings, Nuclei -validate actively confirms exploitability beyond signature match. Validated findings get priority_score boost;	P0	Validated finding shows 'CONFIRMED EXPLOITABLE' badge; unvalidated criticals demoted from Top 10 if reasoning agrees

ID	Requirement	Priority	Acceptance Criteria
	unvalidated 'critical' get penalty		
FR-SCN-08	Recurring scans (daily/weekly cron per asset)	v1.1	Deferred
FR-SCN-09	Cloud scanners (Prowler), IaC (Checkov), network (Nmap)	v1.1	Deferred

7.4 Threat Intelligence Enrichment

ID	Requirement	Priority	Acceptance Criteria
FR-INT-01	NVD enrichment: CVSS v3 score + vector + CWE + description	P0	95% of findings with CVE have CVSS populated within 60s of scan complete
FR-INT-02	CISA KEV check: O(1) Redis SISEMEMBER lookup	P0	KEV findings flagged 'EXPLOITED IN WILD' badge; KEV list refreshed daily 02:00 UTC
FR-INT-03	FIRST EPSS score + percentile (batch up to 100 CVEs/call)	P0	EPSS shown as colored percentile bar; cached 24h
FR-INT-04	Priority score = round(epss × cvss × (2 if kev else 1) × asset_weight, 3)	P0	Same scan yields identical ranking on re-fetch; tiebreaker: priority DESC, kev DESC, cve_id ASC
FR-INT-05	Top 10 ranked findings surfaced prominently	P0	ScanDetail shows 'Top 10 — Fix Immediately' above full table

7.5 AI-Powered Analysis

ID	Requirement	Priority	Acceptance Criteria
FR-AI-01	Per-finding AI enrichment via Claude (claude-sonnet-4-5): plain-English explanation + numbered remediation steps	P0	AI output rendered in Finding Detail panel; cached on Finding row, never re-called
FR-AI-02	Structured JSON output via strict system prompt; Pydantic parse + 1 retry on failure	P0	Parse failure rate <2% across 1000 findings
FR-AI-08	★ DIFFERENTIATOR — Source-call reachability for SCA findings. Parse cloned repo's AST; check	P0	50-finding scan completes reachability analysis in <60s; reasoning visible in panel; unreachable CVEs demoted in

ID	Requirement	Priority	Acceptance Criteria
	whether vulnerable function is actually called, not just imported transitively. Adjust priority_score 0.7× unreachable / 1.2× reachable		sort
FR-AI-10	★ DIFFERENTIATOR — Agentic chat over scan data. Claude with tool_use access to list_findings, get_finding, get_scan, get_asset, search_cves. Answers 'what should I fix this sprint?', 'what changed since last scan?'	P0	Agent answers 5 benchmark questions correctly; streaming UI; citations link to findings
FR-AI-04	Executive summary: single Claude call after all findings enriched; 3–5 sentence CISO-grade summary	P0	Stored on Scan.exec_summary; surfaced at top of ScanDetail and /executive page
FR-AI-05	AI usage tracking: input/output tokens per call → ai_calls table → /admin/ai-usage dashboard (split by call_type: enrich, agent, exec)	P0	Daily cost visible to admin; alerts on >120% of average
FR-AI-06	No customer source code, credentials, or PII sent to AI — only CVE metadata, severity, asset name, fingerprint, and (for FR-AI-08) opted-in AST snippets of vulnerable call sites	P0	Prompt audit log shows only allowed fields; documented in /security; reachability snippets capped at 200 lines
FR-AI-07	False-positive flagging (manual + simple heuristic)	P0	User can mark FP with note; package-not-in-manifest heuristic auto-flags candidates
FR-AI-03	Severity override (DEPRIORITIZED): kept as v1.1 — priority_score already handles risk differentiation cleanly	v1.1	Deferred. priority_score (which includes reachability + validation + EPSS + KEV + asset weight) makes a separate severity_final field redundant for v1.0

7.6 Outputs & Integrations

ID	Requirement	Priority	Acceptance Criteria
FR-OUT-01	One-click Jira ticket creation from any Finding using AI-generated	P0	Ticket created in configured project; jira_issue_key stored; button disabled

ID	Requirement	Priority	Acceptance Criteria
	summary/description/labels		afterwards
FR-OUT-02	Slack webhook notifications on scan complete (critical/KEV only by default) + per-finding threads for critical/KEV findings tagging asset owner	P0	Critical finding → Slack thread w/ AI summary + asset owner tag + PR/Jira buttons
FR-OUT-03	PDF report export (executive or technical template) via ReportLab; stored in MinIO	P0	PDF renders in Adobe + Preview + Chrome; <5MB for 100-finding scan
FR-OUT-04	★ DIFFERENTIATOR — AI-generated fix PRs. Open actual git PRs for Gitleaks (remove secret + .gitignore + rotation notes), Trivy SCA (bump fixed_version + lockfile update), and Trivy misconfig (Claude-generated patch, ≤50 line diff)	P0	Gitleaks finding → PR within 30s; Trivy SCA finding → PR with version bump; pr_url visible on Finding row; PR status reflects open/merged/closed
FR-OUT-05	CSV export of findings	P0	All non-suppressed findings exported with all enrichment columns
FR-OUT-06	Generic outbound webhooks (HMAC-SHA256 signed, 3x retry)	v1.1	Deferred — most customers want PR/Jira/Slack; generic webhooks can wait

7.7 User Interface

ID	Requirement	Priority	Acceptance Criteria
FR-UI-01	Dashboard with 4 KPI cards + intel-freshness panel	P0	Loads in <1s on broadband; cards show real counts within 2s of page mount
FR-UI-02	Scans list with sort/filter/search	P0	Sort by date/status; filter by severity present; full-text search by target
FR-UI-03	Finding Detail Sheet (right-side panel) with Summary / Remediation / Reachability / Raw tabs	P0	Opens on row click; J/K keyboard nav between findings; Esc closes
FR-UI-08	★ DIFFERENTIATOR — Single-screen CISO view (/executive). Posture score (0-100), week-over-	P0	Loads in <500ms; present mode hides nav and enlarges text; visually board-

ID	Requirement	Priority	Acceptance Criteria
	week trend, 3 hero stats (Validated Critical · KEV in Wild · Reachable High), AI exec paragraph. 'Present mode' fullscreen toggle. URL-shareable with as_of date		room-ready
FR-UI-04	Dark mode toggle (next-themes)	P1	Persists across reload; respects system preference on first visit
FR-UI-05	Mobile responsive (375px minimum)	P1	Dashboard, scans list, finding detail usable on iPhone width
FR-UI-06	Accessibility: WCAG 2.1 AA on core flows	P1	Lighthouse a11y ≥90; axe DevTools no critical issues on login/dashboard/scan-detail
FR-UI-07	Ask-Agent floating action button on ScanDetail opens chat Sheet (wires FR-AI-10)	P0	Click → Sheet opens with chat UI; suggested questions visible; streaming responses

7.8 Billing & Tiering

ID	Requirement	Priority	Acceptance Criteria
FR-BIL-01	Tier enforcement: Free 10 scans/mo, Starter 100, Pro 1000, Enterprise unlimited	P0	Scan request returns 429 + upgrade link when over quota
FR-BIL-02	Quota indicator in TopBar + warning Banner at >80% usage	P0	Visible from any page; banner appears at threshold
FR-BIL-03	Pricing page (public, /pricing) with monthly + annual toggle (20% annual discount)	P0	Server-rendered; loads in <1s; all CTAs route to /signup
FR-BIL-04	Stripe checkout for paid tiers	v1.1	Deferred to v1.1; for v1.0 use 'Contact sales' button + manual provisioning

8. Non-Functional Requirements

Category	Requirement	Target
Performance — scan	Full 3-tool scan of medium target (web app + container + repo, ~50 findings)	Complete (incl. AI enrichment) in <2 min P95
Performance — API	GET /scans/{id}/findings (100 findings) P95 latency	<300ms
Performance — frontend	Lighthouse Performance on /scans/[id]	≥85
Performance — first paint	LCP on /dashboard (Next.js streaming RSC)	<1.5s on 4G
Concurrency	Concurrent scans on a single Hetzner CX31 (4 vCPU, 8 GB)	5 in parallel with no failed enrichments
Availability	Uptime SLO (single-region MVP)	99.5% (≈3.6h/mo allowed downtime)
Data durability	Postgres backups via pg_dump → MinIO; restore tested	RPO ≤24h, RTO ≤4h
Security — auth	JWT signing (HS256) with rotated secret; bcrypt cost factor 12+	Documented rotation runbook
Security — transport	TLS 1.2+ enforced via Caddy; HSTS preload-ready	securityheaders.com grade A
Security — isolation	Multi-tenant isolation tested via property-based test on every CI	0 cross-tenant leaks
Security — secrets	Customer Jira/Slack/Webhook secrets encrypted at rest (Fernet)	No plaintext secrets in DB dump
Privacy — AI	No source code, credentials, customer PII sent to Anthropic API	Documented in /security; verified via prompt audit
Compliance posture	Public /security page covering encryption, isolation, data retention	Live; supports vendor risk questionnaires
Observability	Sentry for backend + frontend errors; UptimeRobot 5-min checks	<2 min alert on downtime
Scalability — v1.0	Single-VPS deployment	Up to 50 paying orgs / ~2000 scans/mo

Category	Requirement	Target
Scalability — v1.1	Horizontal worker scaling via Celery	Add workers without DB schema change
Cost — unit economics	COGS per scan at Starter tier (compute + AI tokens)	<30% of revenue

9. Technical Architecture

9.1 High-level

A single Hetzner CX31 VPS runs Docker Compose with: Caddy (reverse proxy, auto-SSL) → Next.js 15 frontend (port 3000) and FastAPI backend (port 8000) → Celery workers (Redis broker) → PostgreSQL 16 (state) + MinIO (PDF + repo clones). Cloudflare in front for DNS + DDoS. Auth.js v5 on the frontend proxies credentials to FastAPI /auth/token — FastAPI remains the source of truth for JWT issuance and password hashing (passlib bcrypt).

9.2 Backend (Sathish)

- FastAPI + Uvicorn + Pydantic v2 — typed API, OpenAPI auto-published at /docs.
- SQLAlchemy + Alembic — 5 core tables: Org, User, Asset, Scan, Finding. Every table has org_id FK and every query filters by it.
- Celery 5 + Redis 7 — scan execution + intel enrichment + AI batching. Tasks idempotent and retryable.
- Scanner adapters subclass BaseAdapter with run(target, options) → list[Finding]. Adding a 4th scanner in v1.1 means writing one file.
- Anthropic Python SDK calls Claude with strict JSON-output system prompts; Pydantic v2 parses + 1 retry on failure.

9.3 Frontend (Karthik)

- Next.js 15 App Router with route groups: (auth) for /login /signup, (app) for authenticated pages, (marketing) for public pages.
- Auth.js v5 with CredentialsProvider; JWT session strategy (no DB adapter needed).
- shadcn/ui (Radix + Tailwind) for all primitives: Dialog, Sheet, DataTable, Form, Toast, etc.
- TanStack Query for server-state caching + polling; TanStack Table (via shadcn DataTable) for findings/scans tables.
- react-hook-form + zod for forms; sonner for toasts; lucide-react for icons; next-themes for dark mode.
- SSE for live scan progress, with TanStack Query refetch interval as fallback.

9.4 Data flow (single scan)

- User clicks 'New Scan' → Next.js mutation POSTs to FastAPI /scans → row written, Celery group dispatched.
- Celery group runs Nuclei + Trivy + Gitleaks in parallel; findings written to Postgres with org_id.

- Chord callback dispatches `enrich_findings_task`: NVD → KEV → EPSS → `priority_score`.
- Then `ai_enrichment_task` batches findings (5 at a time) and calls Claude in parallel.
- Finally `exec_summary_task`: one Claude call with top 10 findings → `Scan.exec_summary`.
- Throughout, progress hash in Redis is updated; SSE pushes to Next.js client; UI re-renders.

9.5 Security architecture (deep dive)

- All endpoints require Bearer JWT (verified server-side; Auth.js on client never trusts session alone).
- RBAC enforced at the FastAPI dependency layer (`@require_role` decorator), not the UI layer.
- `org_id` derived from JWT subject, never from request body — prevents IDOR.
- Customer secrets (Jira API token, Slack webhook, webhook secret) encrypted at rest with Fernet.
- Outbound to NVD/EPSS/KEV/Claude uses no customer-identifying data beyond CVE IDs.

10. MVP Scope (v1.0)

10.1 In Scope

In Scope (v1.0)	Rationale
3 scanners: Nuclei, Trivy, Gitleaks	Covers ~80% of mid-market buyer asks (web + container + repo)
Multi-tenant auth + RBAC	Required for any B2B sale
Threat intel (NVD + KEV + EPSS)	Differentiates from raw scanner output; required for 'real-world risk' positioning
AI enrichment (Claude) — per-finding + exec summary	Core value-add; what justifies the price vs free tools
★ Source-call reachability (FR-AI-08)	Structural moat vs DefectDojo — they cannot read source
★ Exploit validation mode (FR-SCN-13)	Structural moat — they don't run the scanner
★ Agentic chat over scan data (FR-AI-10)	AI-first positioning; DefectDojo exposes data via MCP but ships no native agent
★ AI-generated fix PRs (FR-OUT-04)	Demo 'wow' moment — they create tickets, we create commits
★ GitHub App for PR-time scanning (FR-SCN-12)	Shift-left; structurally impossible for ingest-only platforms
★ Single-screen CISO view (FR-UI-08)	Sales asset; one URL for the board
Jira + Slack threads + PDF outputs	Workflow integration drives daily-active usage
Self-service signup + verify + onboard wizard	Removes us as the bottleneck for trials
Tier enforcement (Free/Starter/Pro)	Required even without Stripe — proves pricing model
Production deploy on Hetzner + Caddy + Cloudflare	Real domain, real customers, real money

10.2 Out of Scope (deferred)

Deferred to v1.1 / Later	Rationale
Prowler (cloud), Checkov (IaC),	Triplies the scope; deliver after we know first customer's actual

Deferred to v1.1 / Later	Rationale
Nmap (network)	asks
Severity override / escalation (FR-AI-03)	priority_score already handles risk weighting cleanly; separate severity_final field is redundant UX overhead
Generic outbound webhooks (FR-OUT-06)	Most customers want PR/Jira/Slack which are already in v1.0; generic webhooks ship in v1.1
Scan delta side-by-side UI	Delta computed in v1.0 (NEW/PERSISTED/FIXED tags), but rich comparison UI deferred
MITRE ATT&CK kill-chain clustering	Impressive demo, low daily value
OWASP Top 10 heatmap	Reporting flourish; ship after compliance reports
Compliance reports (SOC2, PCI, HIPAA mappings)	Heavy templating work; only needed by 30% of buyers
Recurring scans (cron per asset)	Useful but not urgent; Celery Beat already in place
SSO (SAML / OIDC)	Enterprise tier only; not blocker for SMB
Stripe checkout (paid tiers self-serve)	Manual provisioning is fine for first 10 customers
On-prem / air-gapped deployment	Enterprise-only; major engineering shift

11. Success Metrics & KPIs

Metrics tracked from Week 12 launch and monthly thereafter.

Metric	v1.0 Target (Week 12)	Month 4 Target
Paying customers	1	5
Annual Recurring Revenue (ARR)	\$2.4k (1 × Starter)	\$15k+
Scans run per week (across all customers)	20+	200+
Time from scan complete → AI-enriched findings visible (P95)	<2 min	<90s
Findings → Jira ticket conversion rate	≥15%	≥25%
AI cost per scan (Starter tier average)	<\$0.30	<\$0.20 (with prompt caching)

Metric	v1.0 Target (Week 12)	Month 4 Target
Lighthouse Performance score (production)	≥85	≥90
Uptime (rolling 30-day)	≥99.5%	≥99.9%
Cross-tenant data leaks discovered	0	0
Customer NPS (after 30 days of use)	—	≥30

12. Competitive Landscape

This section addresses the strongest direct competitor (DefectDojo) and the adjacent landscape, plus our defensible positioning. Last reviewed against vendor websites and product pages May 21, 2026.

12.1 DefectDojo (closest competitor)

DefectDojo is a mature, well-funded vulnerability management / ASPM platform with open-source and paid 'Dojo Pro' tiers. They aggregate findings from 200+ security tools, deduplicate, prioritize, and report. Recent additions: AI-powered enrichment (KEV/EPSS), AI-powered auto-triage and deduplication, MCP integration, and AI-powered report generation.

Crucial architectural fact: DefectDojo is an ingest/aggregation platform — they do NOT run scanners and do NOT hold customer source code at scan time. They process findings emitted by tools customers run themselves.

12.2 Structural moats — what they cannot replicate

Six v1.0 features depend on running scans ourselves and/or holding source at scan time. These are not features DefectDojo has 'not gotten to yet' — they require a different product architecture:

- FR-SCN-12 (PR-time scanning via GitHub App): runs scanners on PR diff before merge. They cannot scan what hasn't been scanned by a customer yet.
- FR-SCN-13 (Exploit validation mode): Nuclei -validate actively probes the target. They have the finding, not the scanner.
- FR-AI-08 (Source-call reachability): parses customer repo AST to confirm vulnerable functions are reachable from real code. They lack source access; their reachability is dependency-graph only.
- FR-AI-10 (Agentic chat over scan data): a native Claude agent that uses tool_use to answer 'what should I fix?'. They expose data via MCP for external AIs but ship no native agent.
- FR-OUT-04 (AI-generated fix PRs): opens actual git PRs with code changes. They create tickets, not commits.
- FR-UI-08 (Single-screen CISO view): opinionated, projection-ready posture page. They are configurability-first dashboards by design philosophy.

12.3 Areas where DefectDojo is genuinely better (be honest)

- Integration breadth — 200+ scanners ingested vs our 3 run natively.
- Maturity, community, and enterprise references — 10+ years of production use.
- Aggregation of pre-existing security stacks — if a customer already runs 12 tools, DefectDojo wins immediately.
- Configurability for large security teams with idiosyncratic workflows.

We do not compete on these. We do not try to. Our target buyer is the customer with no existing AppSec stack — DefectDojo's wedge for them is weak because they would have to deploy scanners and DefectDojo separately.

12.4 Other competitors and how we differ

- Snyk / Wiz (enterprise ACV \$50k+) — out of price range for our SMB/mid-market buyer.
- Aikido Security — closest in positioning (AI + multi-scanner SaaS); compete on AI quality + structural moats above.

- Nessus / Qualys — scanner-first, dated UX, no AI/intel layer, no developer workflow.
- ArmorCode — enterprise ASPM; same TAM problem as Snyk.
- Open-source dashboards (DefectDojo open-source, Faraday) — self-hosted, no AI, no managed service; we are the managed-AI alternative.

12.5 Positioning statement

For sub-200-person companies without a dedicated security engineer, we are the AI-first, scanner-included alternative to assembling DefectDojo + Nuclei + Trivy + Gitleaks + custom AI prompts. We ship the scanners, run them on a schedule and at PR time, validate exploitability, check reachability against source, and open fix PRs — not just create tickets. The whole stack is one signup and one URL.

13. Risks & Mitigations

Risk	Likelihood	Impact	Mitigation
Mature OSS competitor (DefectDojo) is 'good enough free' for our target buyer	High	High	Lean into structural moats (FR-SCN-12 PR scan · FR-AI-08 reachability · FR-OUT-04 fix PRs · FR-UI-08 CISO view) — features DefectDojo cannot deliver as an ingest-only platform. Position as 'scanner-included, AI-first, done-for-you' vs their 'aggregate + configure'
AI cost overrun (Claude tokens) eats unit economics	Medium	High	Per-scan cost cap; prompt caching for repeated CVE contexts; max_tokens tight; daily admin alerts; reachability analysis batched at finding-group level not per-finding
NVD / EPSS / KEV API rate limits hit during peak	Medium	Medium	Aggressive Redis caching (24h TTL); NVD API key (free, raises limits); exponential backoff
Cross-tenant data leak (catastrophic)	Low	Critical	org_id filter on EVERY query; property-based test in CI; manual audit each month
12-week timeline slips due to differentiator features added	Medium	High	Severity override + generic webhooks + scan delta UI cut to make room. Weekly demos. Friday bug-bash. Never start phase N+1 without phase N tagged
AI fix PRs (FR-OUT-04) generate bad patches that customer merges	Medium	High	Diff size cap (≤ 50 lines for misconfigs); never auto-merge — always PR for human review; PR description explicitly says 'AI-generated, review before merge'; start with low-risk fix types only (Gitleaks, version bumps)
Source-call reachability (FR-AI-08) leaks source to AI provider	Low	Critical	Snippets capped at 200 lines; only call-site context, never full files; documented in /security; opt-out flag per org
Scanner false-positive rate frustrates first customer	High	Medium	Reachability + validation modes (FR-AI-08, FR-SCN-13) reduce FP at source; manual flag from day 1
Karthik unfamiliar with Next.js App Router specifically (vs	Medium	Medium	Week 1 paired setup; lean on shadcn/ui (familiar Radix patterns); pre-built

Risk	Likelihood	Impact	Mitigation
general React)			Auth.js patterns
Anthropic API outage during demo / customer scan	Low	Medium	Graceful degradation: scan still completes with intel enrichment; AI sections show 'pending' state
Solo person on-call burnout (2-person team)	Medium	Medium	UptimeRobot alerts both phones; documented runbook (Day 50); each owns half the system, paired on incident

14. Release Plan / Roadmap

Release	Timing	Headline Features
v1.0	Week 12 (Aug 2026)	3 scanners · intel enrichment · Claude AI · Jira/Slack/PDF · multi-tenant SaaS live
v1.0.x	Weeks 13–16	Customer-driven polish · prompt caching · audit log UI · feature voting
v1.1	Months 4–5	Prowler (cloud) · Checkov (IaC) · recurring scans · Stripe self-serve checkout · scan delta UI
v1.2	Month 6	SSO (SAML/OIDC) · MITRE ATT&CK clusters · compliance report packs (SOC2/PCI) · public API rate-limit increase
v1.3+	Month 7+	Nmap · OWASP heatmap · on-prem deploy option · CI/CD pipeline plugin (GitHub Action) · public roadmap voting

Roadmap is published on </roadmap> and updated when customers request features. Customer pull ranks higher than engineering push.

15. Open Questions & Assumptions

15.1 Open questions to resolve in Week 1–2

- Domain name and brand — not yet locked in (Week 9 buy deadline).
- First customer profile — pilot signed or still cold-outreach? Affects Week 11 outreach tone.
- Karthik's familiarity with Next.js App Router specifically (vs general React) — confirm in Week 1 pair session; pad Week 2 if needed.
- Pricing — Starter at \$29 vs \$49 vs \$99? Test in Week 10 demos.

15.2 Working assumptions

- Anthropic Sonnet 4.5 pricing remains within current bands; if it drops, COGS improves; if it rises 2×, switch to Haiku for non-critical findings.
- Hetzner single-VPS holds for first 50 paying orgs (~2000 scans/mo); v1.1 introduces horizontal worker scaling.
- NVD/EPSS/KEV remain free public APIs through 2026 (no signs of monetization).
- Mid-market buyers will accept SaaS-only (no on-prem requirement until v1.3 enterprise tier).
- DefectDojo will likely add native scanning + agentic chat within 12–18 months; window to establish wedge is now.

16. Appendix

16.1 Glossary

- CVE — Common Vulnerabilities and Exposures; standardized identifier for a known vulnerability.
- CVSS — Common Vulnerability Scoring System; severity score 0–10. v3 baseScore is the standard.
- EPSS — Exploit Prediction Scoring System (FIRST.org); probability (0–1) that a CVE will be exploited in next 30 days.
- KEV — Known Exploited Vulnerabilities (CISA); curated list of CVEs with confirmed in-the-wild exploitation.
- Asset weight — Per-customer criticality multiplier (0.5 / 1.0 / 1.5 / 2.0) applied to `priority_score`.
- Priority score — Composite ranking = $\text{round}(\text{epss} \times \text{cvss} \times (2 \text{ if kev else } 1) \times \text{asset_weight} \times \text{reachability} \times \text{validation}, 3)$.
- Reachability — Whether the vulnerable function in an SCA finding is actually called from customer code (FR-AI-08).
- Exploit validation — Active probe (Nuclei -validate) confirming a critical finding is exploitable, not just signature-matched (FR-SCN-13).
- ASPM — Application Security Posture Management; category DefectDojo and similar tools occupy.
- FP candidate — Finding flagged as likely false positive by heuristic or manual review.

16.2 External APIs

- NVD: <https://services.nvd.nist.gov/rest/json/cves/2.0> (free; API key raises rate limit)
- CISA KEV: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json (free, no key)
- FIRST EPSS: <https://api.first.org/data/v1/epss> (free, no key; batch up to 100 CVEs/call)
- Anthropic Claude API: <https://api.anthropic.com/v1/messages> (paid; sk-ant-* API key)
- GitHub Apps API: <https://api.github.com> (PR-time scanning, FR-SCN-12)

16.3 Related documents

- 12-Week Daily Build Plan v1.0 — daily task breakdown with Next.js 15 frontend stack.
- SCHEMA.md — database ER diagram (mermaid).
- SECURITY.md — multi-tenant isolation audit results.

- ACCESSIBILITY.md — Lighthouse and axe DevTools results per release.

END OF DOCUMENT